

Lab02 - Active Scanning

Intro

In the last lab you spent some time “footprinting” your target - in this case, a real-world website. This is done to gather information concerning their public-facing infrastructure potential weaknesses in systems and processes, and make inferences about how systems are maintained and administered. In a real pentest, this allows you to narrow your scope when you begin to actively interrogate their systems, reducing the noise you generate and the chance of being caught.

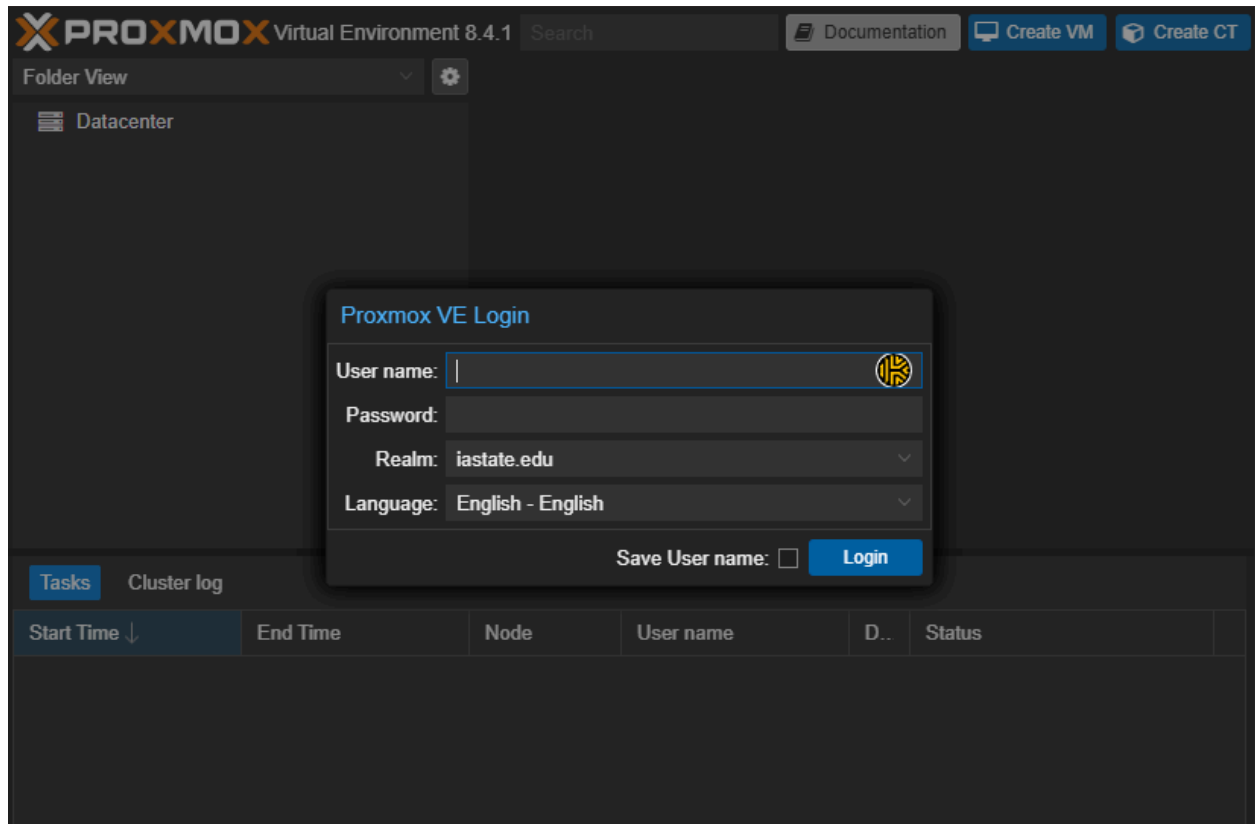
In this lab, you will move on to the next step in penetration testing - scanning and enumeration. **This will be performed within Proxmox ONLY.** This phase allows you to discover publicly-facing devices and services, which allow you to find potential entry points into the system. Scanning involves actively gathering information (compared to passive - just google searches, etc) by interrogating the running machines - typically done by sending packets and waiting for a response.

Depending on how these devices are configured and what detection systems are put in place, the amount of information you can discover may be limited and even alert the target that somebody (you) is poking fingers where they shouldn't be.

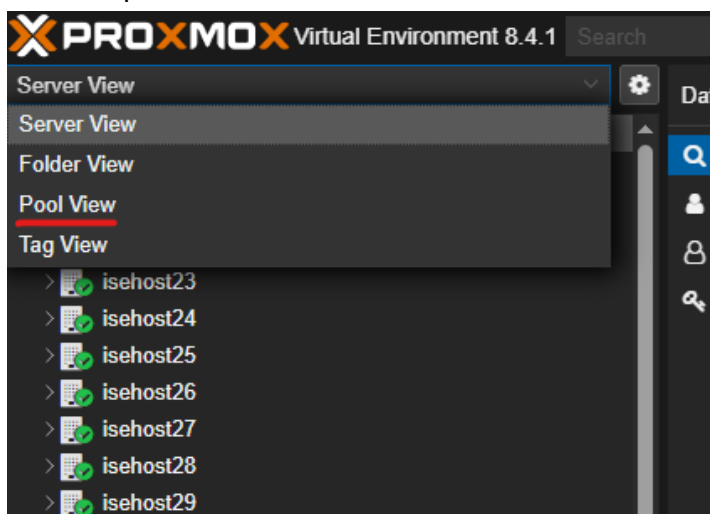
You will first discover what other systems are on your network, then find the open ports on each system, infer which services are running on which operating system, and prepare a list of potential vulnerabilities to be exploited in a future lab.

Needless to say, the following steps should **ONLY BE PERFORMED WITHIN ISELAB**.

1. Log into Proxmox by navigating to <https://iselab.ece.iastate.edu/>.
2. You will be presented with an authentication screen. Enter
 - a. Your netid (do not append the domain)
 - b. Your password
 - c. Select the [iastate.edu](https://iselab.ece.iastate.edu/) realm (should be default)
 - d. Click OK

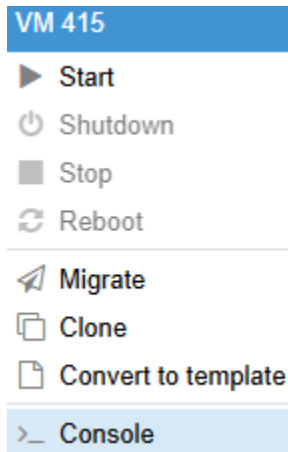


3. For this lab you will use your **Kali machine in ISELab**.
 - a. To view your own resource pool, change from 'Server view' to 'Pool View' in the top left



- b. Open your resource pool to get to your **kali** machine. Login using root/toor)

- c. You can either edit in the console in the web browser window or you can open the console by right clicking and selecting console.



You will be connecting to internal websites (X.X.X.0/24) in this class. However, Kali will forward all traffic to the proxy by default. You have been provided a script in your home directory that will configure exceptions to the proxy.

4. Refer [here for your network range](#). **Be VERY careful** and make sure you know the first three octets of your IP Range (Column H)
5. Read the script and follow its instructions on how to use it. The script is located in the cpre2310:cpre2310 user folder. It is in **/home/cpre2310** Your command should be:
`./noproxy.sh X.X.X`

```
(root@kali)-[~]
# ./noproxy.sh 79.61.216
Writing to /etc/profile...
Writing to /etc/environment...
Writing to /etc/hosts...
Reboot your system to enable the new configuration.
```

6. Check `/etc/profile` and `/etc/environment` to make sure the edits are correct. **If you make a typo, you have to delete the lines the script added in each file and then run it again.**
7. Once you have run the script successfully, reboot for the changes to take effect.

Host Discovery

The first step is to determine what devices are available on your target network. For this lab, you will be scanning your own network (refer [here for your network range](#) - it will be referenced as XX.XX.XX.YY within the next labs). You will use your **Kali machine in ISELab**.

The most basic of methods is to simply send ICMP echo request packets to targeted servers and await a reply. Try pinging your default gateway.

```
ping -c 3 X.X.X.254
```

You should see three response packets, signifying that a machine at the specified IP is operating and configured to allow return pings. While we could manually ping every possible IP address on the network, it's better to automate the process.

In the real world, it's important to document every action you take as a potential red team operator or penetration tester. You may also need to let your client know what steps you are going to take. This depends upon the engagement. If the test is known to the IT staff, then you need to do deconfliction. The term comes from the military and means to remove any potential danger to non-enemy threats. We can think of it as making sure everyone knows we are testing weapons in a certain area so no one gets hurt. The same idea can exist for a penetration test. The idea is to let all the blue folks know what is happening in the test. How else would the blue team/network defenders know if somebody scanning their network is an actual threat or just an exercise? Again, this could vary based on the engagement.

It's also important to save the information from the commands you run. Especially if a network scan takes several hours, we don't want to have to rerun the scan if we didn't save the output the first time.

1. Create a directory called "nmap_scans" in your home directory and change into it. You will be saving the output of your scans in this folder.

Nmap is a versatile tool that is great for scanning machines for ports, services, and vulnerabilities. Nmap has many flags that can customize the type of scan, how fast/slow the scan should be, etc.

Before trying to scan for vulnerabilities and services, it's always a good idea to try and see what hosts exist on a network first. This will significantly reduce the scanning time down the road, as scanning a list of known IPs is much more efficient than asking nmap to scan an entire subnet. To execute a ping scan, the flag is "-sn".

2. `nmap -sn x.x.x.100-125 -oA ping_scan`

By using the -oA flags the output will be saved to three files named ping_scan.gnmap, ping_scan.nmap, and ping_scan.xml. The .gnmap is known as a "grepable" output, which can be easily parsed to grab specific values from the columns.

3. View the output of the ping scan
`cat ping_scan.gnmap`
4. Save all of the discovered IPs to a file. **Do not copy and paste the following command.**
`cat ping_scan.gnmap | awk '{ print $2 }' | grep -v '^Nmap' >> IPs.txt`

```
(root@kali)-[~/nmap_scans]
# cat ping_scan.gnmap | awk '{print $2}' | grep -v '^Nmap' >> IPs.txt

(root@kali)-[~/nmap_scans]
# cat IPs.txt
79.61.216.100
79.61.216.102
79.61.216.104
79.61.216.106
```

It's very important to know the behavior of the tools you use in a penetration test or red team engagement, especially their default settings. For example, before nmap does any type of service scan it will run a ping scan first. If nmap does not get a response from a ping scan, it will assume the host does not exist and not continue the rest of the scan.

Ping scans can be an effective way to find certain hosts on a network, but certain operating systems like Windows block ICMP echo replies by default, preventing them from showing up in typical ping sweeps.

5. Read the man pages of nmap. What nmap flag will override this feature and run a scan without performing a ping scan first?

Part of knowing your tools is understanding what kind of traffic/footprint they are going to create on a network.

6. Open Wireshark and start a new capture

7. Run a default nmap scan: `nmap X.X.X.100-125`

8. Examine the Wireshark output. You will want to filter based upon the source IP of your kali box. How many packets were generated? Why might performing this kind of scan not be a good idea? (No exact number of packets is needed, but include a screenshot of your filtered wireshark output).

Ports and Services

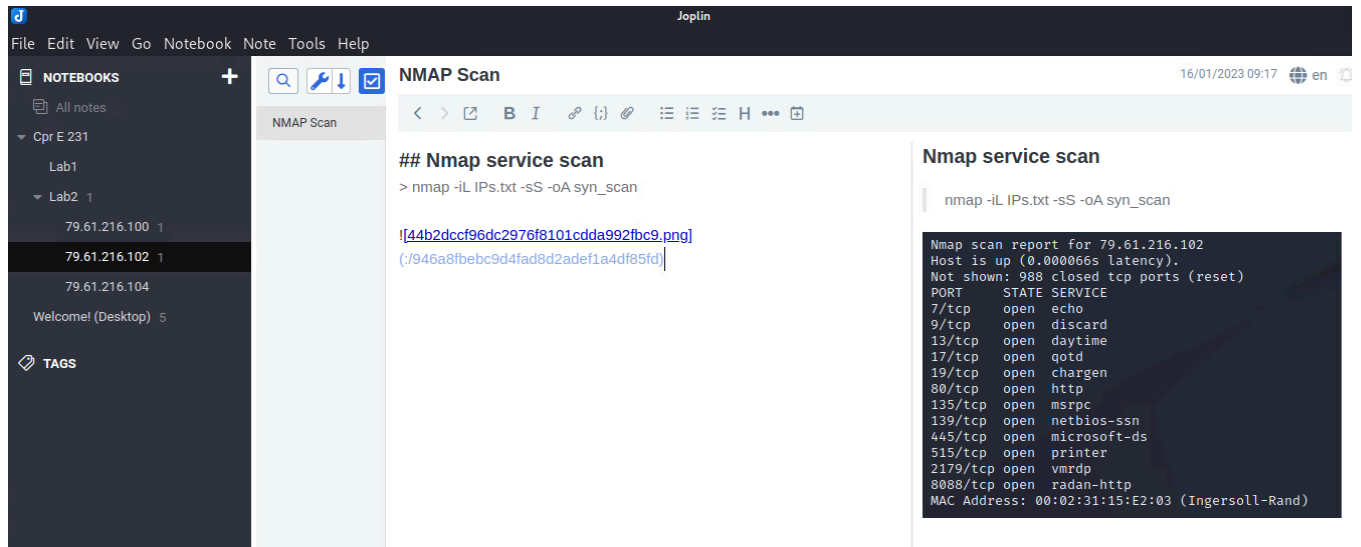
Now that we have a list of hosts to target, we can begin to examine what ports are open on each host in order to infer what services are running and what operating system is running on each host. You will use the information you gathered in the previous section along with incremental output from nmap to learn more about your targets from the range x.x.x.100-125.

1. For each host discovered above, perform a simple SYN scan (also called a half-open scan) with nmap

```
nmap -iL IPs.txt -sS -oA syn_scan
```

2. Take some time to record these findings in Obsidian. As a general guideline, it can be smart to make a folder for each IP address you identified and paste all your findings in those corresponding folders (A reference can be seen below). Note-taking may not be super fun, and it can feel like it slows down the process. However, taking time to do it right and list everything of interest means your life will be easier down the road. The best penetration testers are often the ones who take the best notes.

(Furthermore, it's painful to see a vulnerability on a current engagement that you exploited in the past, but can't remember the steps you took to exploit it.)



3. Create a table, listing the open ports for each host from the range x.x.x.100-x.x.x.125
 - a. For each host, create a list of open ports and the reported service running

Host	Open Ports	Services
32.37.95.101	22 25 53 443	ssh smtp dns https

4. For each host, investigate the open ports and make an educated guess as to what operating system could be running (Google is your friend) - add a new column to your table.
 - a. Google around with the reported services/ports - what OS are they typically found on? - Use this information in your guesses
 - b. List your reasoning for each OS guess

Host	Open Ports	Services	OS guess (1)	OS guess (1) reason
32.37.95.101	22 25 53 443	ssh smtp dns https	Ubuntu 16	Because X was open

5. Rerun a nmap scan on each host, with the added -sV flag to probe for the service protocol and version.

```
nmap -iL IPs.txt -sV -oA service_scan
```

6. Update your services list if needed, and make a second guess for the operating system in a new column. For each host, answer the following in the OS guess (2) column
- Did any of the services change?
 - Did this influence your guess for the operating system?

Host	Open Ports	Services	OS guess (1)	OS guess (1) reason	OS guess (2)	OS guess (2) reason
32.37.95.101	22 25 53 443	ssh smtp dns https	Ubuntu 16	Because X was open	Windows 7	The service Y was now reported and the OS reported by nmap was Z.

7. Now run an nmap scan with operating system discovery and update your table with the operating system as reported by nmap (in a new column).

a. `sudo nmap -iL IPs.txt -O -oA os_scan`

8. **Submit your finished table.**

9. **For each host, were either of your guesses accurate in guessing the operating system? Why might it be valuable to determine operating systems without performing an nmap scan?**

As you might imagine (and have seen in the previous section) nmap is quite noisy when run with default options. This is likely to raise alarms with Intrusion Detection Systems (Security Onion, Suricata, Wazuh, many SIEMs or firewalls), which is undesirable in most cases.

10. **Look through the nmap manual (either via `man nmap` in the terminal, or [here online](#)) and list ways and/or options that you might use nmap such that no alarms might be raised (list three and support your claim).**

Vulnerability Scanning

We now have a fairly good view of the target's public footprint. We know where their machines are on the network, we know what services they are running, we know (or think we know) what the host operating systems are. By knowing the running services and their versions, it is possible to find exploits to known vulnerabilities. Entire databases for vulnerabilities in various software versions exist, along with corresponding exploits and/or attack mechanisms.

For reference, you may want to refer to the [Mitre CVE database](#), [Offensive Security's database](#), and [Rapid 7 database](#).

NSE

Nmap Scripting Engine is a collection of user-submitted scripts that allow vulnerabilities to be quickly detected, and in some cases even exploited. It can be used via the `--script` argument and offers the user quite a bit of flexibility in script selection. [Take a moment to read the online documentation](#). A database of scripts included with [NSE can be found here](#). You can also write your own scripts to run using NSE.

To find vulnerabilities, we can look at the services found and notice that some of the machines are older versions of Windows - for example, XX.XX.XX.100 is running Windows XP. Many different vulnerabilities surround the Windows SMB protocol, so perhaps it is susceptible to a known exploit due to a lack of patches?

1. On your kali machine, open a terminal and run the following command to run vulnerability detection scripts starting with the string "smb-vuln-ms08*" ([see here for complete list of scripts](#)).

```
nmap --script smb-vuln-ms08* XX.XX.XX.100
```

You should see a list of the attempted vulnerability scan and its results. **Take a screenshot of the command vulnerability output.** (It should say, "VULNERABLE:")

2. Try running some additional scans on the target IP range (XX.XX.XX.100-125) by referring to the links above to the included scripts and the knowledge gleaned from the previous lab (HINT, services may be run on non-standard ports...). **Find at least one other vulnerability using NSE and include a screenshot and a short description of the found vulnerability.**

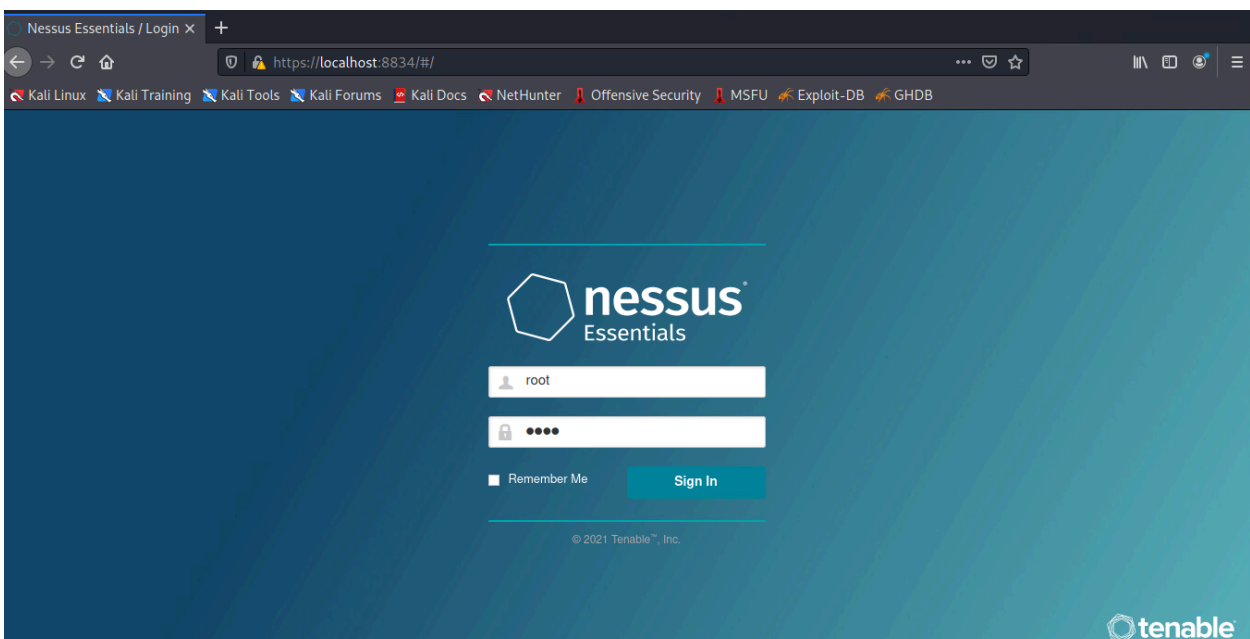
Nessus

In the previous step, we used our knowledge of the running services/versions combined with NSE to find vulnerabilities. While this can be therapeutic on slow weekdays, it's much too slow and tedious to be of any use when securing an entire IT infrastructure against outside threats. The [new project underway in the UK](#) may bring NSE more up-to-date and make it faster to scan an entire network. There is a git repository with [additional scripts](#) and information on how to implement them. However, until that is fully built out, vulnerability scanners, such as Nessus which is an industry standard, can be used to automatically detect and report known vulnerabilities and misconfigurations.

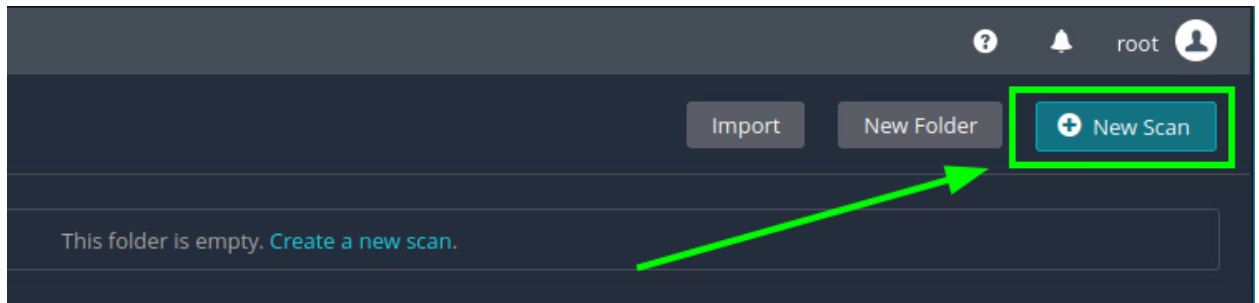
We will be using the Nessus Essentials (old name is Nessus Home Edition) as an alternative means of detecting vulnerabilities. While this may yield very satisfying results, Nessus is very blunt as far as network footprints go and thus is not typically used by attackers due to the large amount of easily identifiable network traffic. It is more likely to be part of an internal analysis run on your own network to make sure there are no vulnerabilities.

The Nessus Essentials' education license has already been installed and configured on your Kali boxes, however free trial licenses can be obtained from the tenable.io website for further experimentation on your own computers against your own machines (**not against ISU machines**).

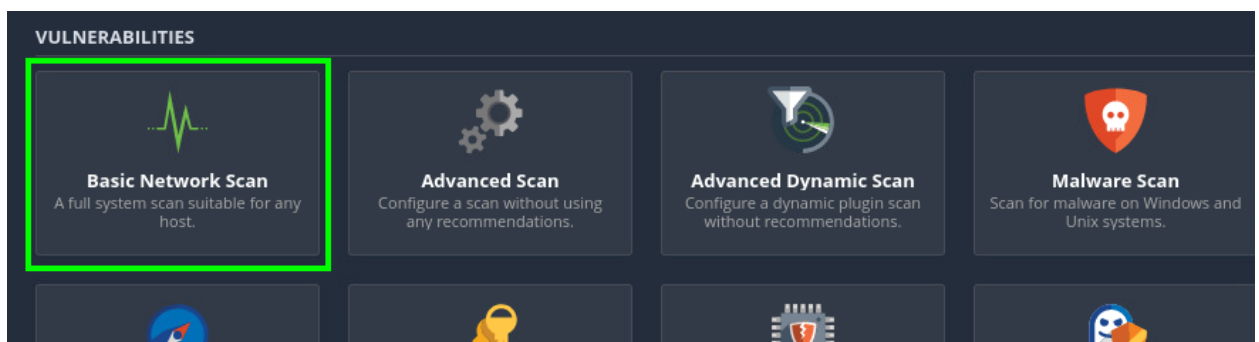
1. Open a Firefox session on your Kali machine and navigate to <https://localhost:8834> (ensure that you use https:// - unencrypted http will not work)
2. If you see a screen saying "Warning: Potential Security Risk Ahead", click "Advanced" → "Accept the Risk and Continue"
3. Log in with the credentials: **root/toor**



4. You should be presented with an empty scanning dashboard. To create a new scan, either click on the “New Scan” button in the upper right-hand corner or the blue “Create a new scan” hyperlink.



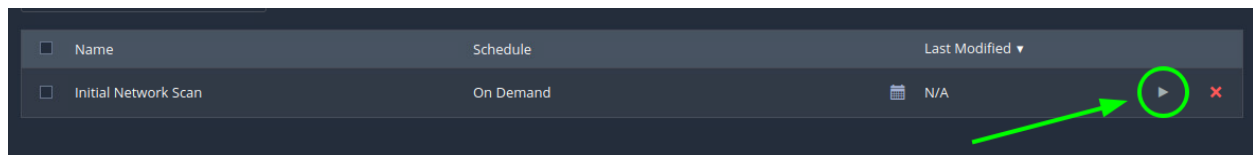
5. There are many different scans that you can run, although some of them require upgrading to the premium edition. For this example scan, select the “Basic Network Scan”.



6. Once you’ve clicked on the desired scan, enter a Name, Description, and list of targets to scan. You will want to scan hosts 100 through 125 on your network (XX.XX.XX.100-125).

A screenshot of the scan configuration form. It has four main sections: 'Name' with the text 'Initial Network Scan', 'Description' with the text 'Basic network scan of vulnerable systems', 'Folder' with a dropdown menu showing 'My Scans', and 'Targets' with the text '79.61.216.100-125'.

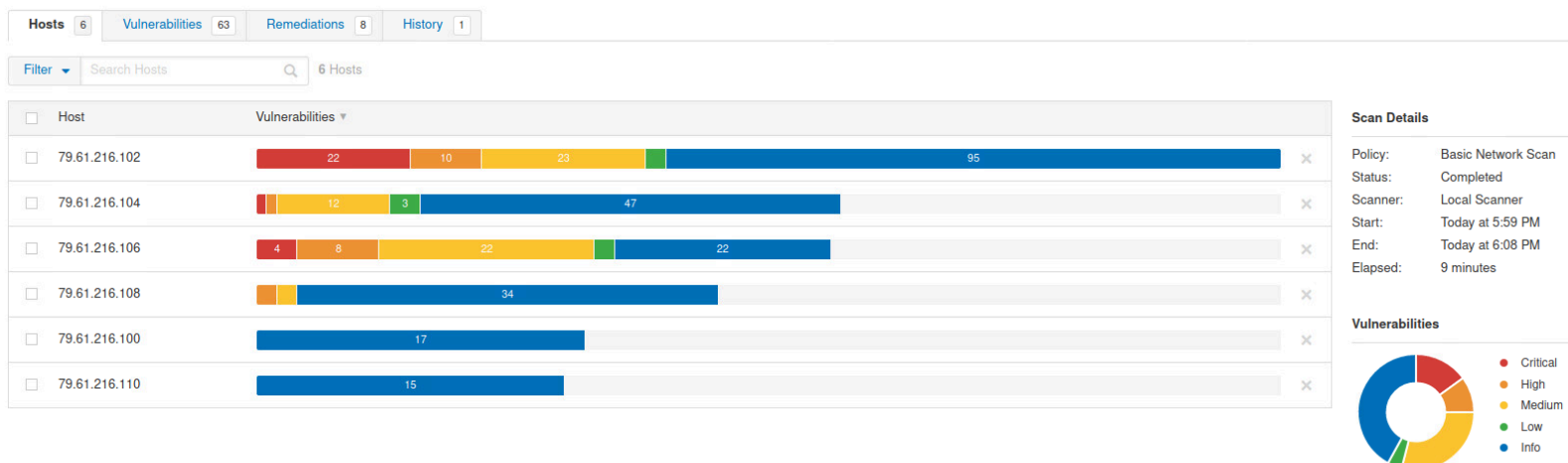
7. Scroll down and click the blue “Save” button in the lower left-hand corner, and you should be returned to the network scanning dashboard.
8. To illustrate the traffic that Nessus generates, open a Wireshark window and start a packet capture.
9. Back in Nessus, on the right-hand side of the newly created scan’s entry column, click on the grey “play” button to manually initiate the scan. Scans can also be scheduled for regular intervals, although for the scope of this lab, we will be using On Demand scanning.



The scan should now begin scanning the specified hosts. This will take a few minutes. You can take this time to iron out more of your report or have a good conversation with your friendly neighbors.

10. While the Nessus scans are taking place, **Look at the traffic captured in Wireshark and comment on what types of packets are being generated.**
11. Once the scan has completed, you can view the scan results by clicking on the completed scan’s column.

Your Nessus scan output MAY LOOK DIFFERENT than the image below. This is just provided as an EXAMPLE.



The presented scan results rank the found vulnerabilities from information-grade to critical-grade. Vulnerabilities can be sorted by host or severity via the tabs at the top of the window.

Browse through the results and see if you can find any vulnerabilities that you found using NSE and list at least one that they have in common.

List 2-3 additional vulnerabilities that interest you and make a note of their CVE and which hosts they were found on

Lab 02 Template

1. **Read the man pages of nmap. What nmap flag run a scan without performing a ping scan first?**
(10 points)
2. **Examine the Wireshark output. How many packets were generated? Why might performing this kind of scan not be a good idea?**
(10 points)
3. **Submit your table for enumerating ports, services, and operating systems**
(10 points)
4. **For each host answer the following:**
(10 points)
 - a. Were either of your guesses accurate in guessing the OS?
 - b. Why might it be valuable to determine operating systems without performing an nmap scan?
5. **List three ways and/or options you might use nmap such that alarms are less likely to be raised**
(10 points)
6. **Take a screenshot of the vulnerability output from scanning X.X.X.100**
(10 points)
7. **Find at least one other vulnerability using NSE and include a screenshot and a short description of the found vulnerability.**
(10 points)
8. **Look at the traffic captured in Wireshark and comment on what types of packets and different protocols are being used.**
(10 points)
9. **Comment on a vulnerability that is common between NSE and Nessus (include screenshot to verify this common vulnerability)**
(10 points)
10. **List 2-3 additional vulnerabilities that interest you and make a note of their CVE and which hosts they were found on**
(10 points)